

Continuous Control Assurance Framework (CCAF)

A Nonproprietary Synthetic Demonstration for Financial and Digital-Payment Environments

Ayodele Timothy Adeniyi, CISA, ACA
Version 1.3.0 | July 16, 2026 | Apache License 2.0

Purpose. CCAF is a vendor-neutral reference implementation that converts selected access, change-management, logging, reconciliation, and payment-monitoring objectives into repeatable analytics. It evaluates every row in supplied in-scope extracts for covered tests, produces review-ready exceptions, reports eligible populations, and preserves artifacts needed to reproduce a run.

What the package contains

Working analytics	Twenty versioned controls across privileged access, change/logging, and reconciliation/payment modules.
Reproducible evidence	Seeded synthetic data, labelled conditions, source-assurance record, SHA-256 manifest, run metadata, calibration record, and regression tests.
Transfer materials	Configurable thresholds, reference SQL, implementation checklist, governance guidance, and cautious framework traceability.

Evidence boundaries

- The repository contains seeded synthetic data, independently written language, and independently written code; it contains no source workbook, employer template, client record, or production material.
- Full-population means every row in the supplied in-scope extract for the covered test. It does not prove source-system completeness or eliminate other audit risk.
- Seeded-condition recall is a software regression result for this fixed synthetic scenario, not a production accuracy rate or proof of loss reduction.
- Priority scores order review work; they are not probabilities of breach, regulatory ratings, or calibrated financial-loss estimates.
- Framework mappings are traceability aids. No referenced organization has reviewed or endorsed CCAF.
- The 20 controls are a bounded reference set selected for relevance, structured-data testability, transferability, analytical variety, and reproducible synthetic validation; they are not a comprehensive control catalog.
- CCAF complements enterprise IAM, SIEM, ITSM, GRC, ERP, fraud, payment-monitoring, and audit platforms. This release runs on demand; live connectors, scheduling, real-time monitoring, and remediation workflow require institution-authorized implementation.
- Version 1.3.0 is a publication-ready local release. Public dissemination should be claimed only after a permanent repository and release identifier exist.

20	9	25,546	169
control tests	manifested datasets	eligible control evaluations	reported exceptions

1. Architecture and Control Coverage

1. Validate	2. Evaluate	3. Report	4. Preserve
Schemas, keys, timestamps, and selected relationships	Deterministic rules and robust statistical screens	Typed exceptions and per-control eligible populations	Hashes, configuration, calibration status, and run metadata

Blocking Critical or High data-quality findings stop execution. Every successful control returns both exceptions and the population actually eligible for that test; the framework no longer assigns synthetic module risk tiers.

ID	Control test	Eligible population	Severity
PA-01	Terminated user retains active privileged access	Active privileged grants	Critical
PA-02	Privileged grant lacks approver	Active privileged grants	High
PA-03	Self-approved access grant	Active grants	High
PA-04	Dormant privileged account	Active privileged users	Medium
PA-05	Toxic entitlement pair	Users with active grants	Critical
PA-06	After-hours authentication outlier	Active privileged users	Medium
PA-07	Expired temporary privileged access	Active temporary privileged grants	Critical
CM-01	Implemented change lacks approval	Change records	High
CM-02	Approver also implements change	Change records	High
CM-03	Emergency change lacks review	Emergency changes	Medium
CM-04	Deployment lacks valid change record	Deployment events	Critical
CM-05	Log source exceeds heartbeat	Log sources	High
CM-06	Emergency-change rate spike	Portfolio comparison	Medium
CM-07	Implemented change lacks test evidence	Change records	High
TR-01	Ledger item lacks processor match	Ledger records	High
TR-02	Ledger/processor amount difference	Matched records	High
TR-03	Duplicate transaction identifier	Unique transaction IDs	Critical
TR-04	Aged unreconciled item	Ledger records	Medium
TR-05	Transaction-velocity outlier	Recently active accounts	Medium
TR-06	Repeated activity below limit	Accounts in ledger	High

Detection and interpretation

Deterministic controls identify records satisfying a defined condition. Statistical screens use a robust z-score based on the median and median absolute deviation. Statistical results are leads for human review, not findings of intent or culpability. All bundled thresholds are demonstration defaults stored in `config/defaults.json`.

2. Validation and Transparent Reporting

The generator labels 165 deliberately injected control/entity conditions. Automated regression tests detected 165 of 165 seeded conditions across all 20 controls in this fixed scenario. Four additional statistical exceptions were also reported; because the background synthetic data can naturally satisfy an outlier rule, they are identified as additional observations rather than presumed false positives.

Module	Seeded	Detected	Recall	Additional observations
Privileged Access	39	39	100%	2
Change and Logging	49	49	100%	0
Reconciliation and Payments	77	77	100%	2

Population reporting

Each control reports exceptions per 1,000 eligible entities. Module summaries add the six denominators as control evaluations and report exceptions per 1,000 evaluations. These rates are descriptive; they are not interchangeable with incident rates or institution-level risk ratings.

Module	Controls	Evaluations	Exceptions	Per 1,000
M1 Privileged Access	7	2,120	41	19.34
M2 Change & Logging	7	1,654	49	29.63
M3 Reconciliation & Payments	6	21,772	79	3.63

Demonstration outputs

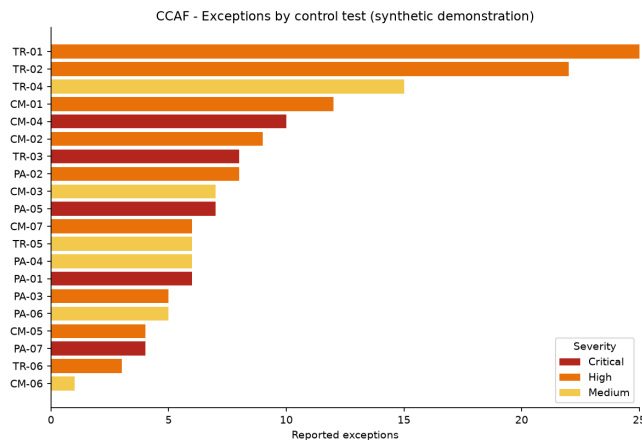


Figure 1. Exceptions by control and severity.

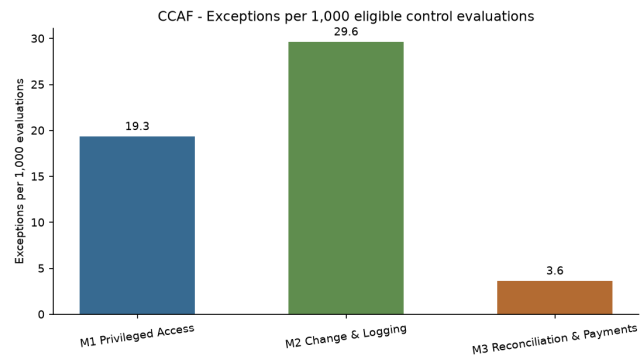


Figure 2. Exceptions per 1,000 eligible control evaluations.

Priority score

Priority score = configurable severity weight x exposure factor (1.0-2.0). It orders review work within the demonstration. It is not a loss probability, compliance rating, or empirically calibrated risk score.

3. Implementation, Governance, and Traceability

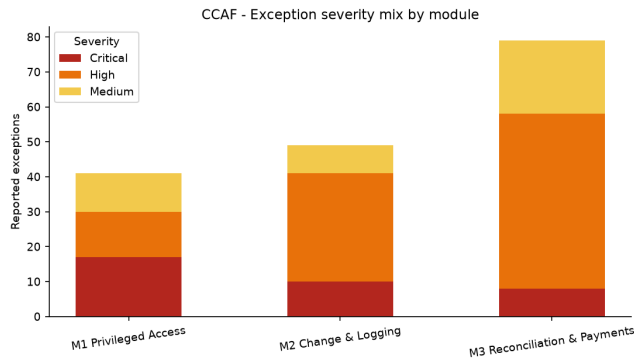


Figure 3. Severity mix by module.

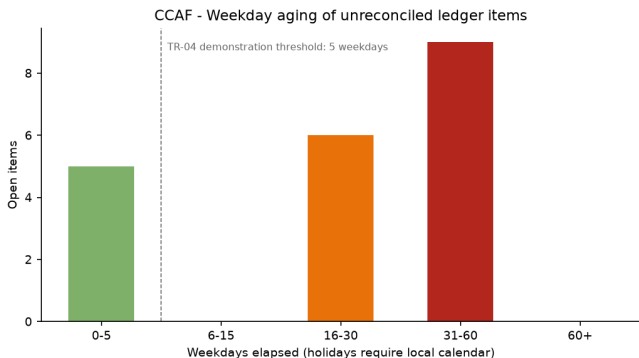


Figure 4. Weekday aging; production requires an approved holiday calendar.

Control-assurance lifecycle

A production conclusion requires more than exception analytics. Implementers should document control scope and design, configuration and implementation, source completeness and accuracy, operation across the period, rollforward after relevant changes, and disposition of reported exceptions.

Phased implementation

Phase	Required work
0 - Authorize	Approve scope, data access, schemas, thresholds, calendars, severity, and escalation.
1 - Pilot	Run historical data, adjudicate every exception, measure labelled recall and reviewer effort, and calibrate.
2 - Operationalize	Schedule authorized runs, integrate ticketing/GRC, apply retention and access controls, and monitor drift.
3 - Govern	Obtain required approvals, train a second operator, revalidate after changes, and contribute only nonconfidential improvements.

Framework traceability

Module	Primary relevance	Interpretive boundary
Privileged Access	NIST CSF PR.AA/GV.RR; FFIEC access administration; PCI DSS 7/8/10	Supports evidence organization; does not establish compliance.
Change and Logging	NIST CSF PR.PS/DE.CM/DE.AE; FFIEC development and operations; PCI DSS 6/10	Control results require institutional scope and adjudication.
Reconciliation and Payments	FFIEC payment-system reconciliation and integrity topics; supporting NIST detection relationships	NIST/PCI entries are supporting relationships, not direct reconciliation requirements.

Governance artifacts

A successful run creates the input hash manifest, source-assurance record, data-quality report, typed exception files, per-control summaries, calibration record, run metadata, and seeded-condition validation summary. The demonstration leaves independent row-count and control-total reconciliation unresolved for all 9 datasets. Adopting institutions must complete those fields, define retention and remediation requirements, and preserve exception dispositions.

4. Limitations, References, and Release Status

Limitations

- Synthetic validation proves software behavior only for the fixed seeded scenario; it does not establish production precision, recall, adoption, or loss reduction.
- Source-extract completeness, field mapping, privacy, holiday calendars, expected activity, and thresholds must be validated locally; file hashes alone do not establish completeness.
- The framework is not a complete cybersecurity, fraud, anti-money-laundering, audit, or compliance program.
- Reference SQL uses database-dependent boolean, interval, and timestamp patterns and must be adapted and tested on the target platform.
- No agency, standards body, employer, client, examiner, or independent reviewer is represented as endorsing this version.

Authoritative references

1. NIST, **The Cybersecurity Framework (CSF) 2.0**, NIST CSWP 29 (2024), <https://doi.org/10.6028/NIST.CSWP.29>.
2. NIST, **Information Security Continuous Monitoring**, SP 800-137 (2011), <https://doi.org/10.6028/NIST.SP.800-137>.
3. FFIEC, **Cybersecurity Assessment Tool Sunset**, <https://www.ffiec.gov/cyberassessmenttool.htm>. FFIEC states that it does not endorse a particular replacement tool.
4. FFIEC, **Information Technology Examination Handbook InfoBase**, <https://ithandbook.ffiec.gov/>.
5. PCI Security Standards Council, **PCI DSS v4.x**, <https://www.pcisecuritystandards.org/standards/pci-dss/>.
6. U.S. Securities and Exchange Commission, rules implementing Sarbanes-Oxley Act Section 404 internal-control reporting requirements.
7. The Institute of Internal Auditors, **GTAG: Continuous Auditing and Monitoring, 3rd Edition** (2025), <https://www.theiia.org/en/content/guidance/recommended/supplemental/gtags/continuous-auditing-and-monitoring>.

Repository package

The package includes source code, seeded data and labels, JSON configuration, automated tests, reference SQL, source-assurance and run artifacts, generated exceptions and summaries, dashboards, governance and implementation documents, Apache-2.0 license, changelog, version file, and citation metadata. The PDF is reproducible from `scripts/build_methodology_pdf.py`.

Release status: Version 1.3.0 is a publication-ready local release dated July 16, 2026. A repository URL, release URL, commit hash, or external-review claim must be added only after the corresponding event can be independently verified.